

Fix What Matters to Your Business

Summary of Vulnerabilities & Threats

31 October – 6 November 2022

This week witnessed the discovery of 528 vulnerabilities out of which nine gained the attention of security researchers worldwide. Among these nine, three Zero-day and two vulnerabilities are awaiting re-analysis on the NVD. Hive Pro Threat Research Team advises organizations to patch this vulnerability as soon as possible.

This week also witnessed the attackers exploiting the Follina vulnerability (CVE-2022-30190) to compromise the Domain Controllers and a huge demand for BlueFox Stealer on the darknet from threat actors

Further, we also observed 3 Threat Actor groups being highly active in the last week. First was the APT 10, a Chinese threat actor, popular for Information theft and espionage distributed LODEINFO malware. The second was the APT 36, a Pakistani threat actor group, popular for Information theft and espionage leveraged the LimePad backdoor against the Indian government. The third was the Back Basta Ransomware Group, a threat actor popular for the financial crime that exploited Microsoft flaws and used an EDR defense evasion tool created by FIN7. Common TTPs which could potentially be exploited by these threat actors or CVEs can be found in the detailed section.

Published Vulnerabilities	Interesting Vulnerabilities	Active Threat Groups	Targeted Countries	Targeted Industries	ATT&CK TTPs
528	9	3	51	23	56

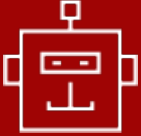
Detailed Report

⚙ Interesting Vulnerabilities

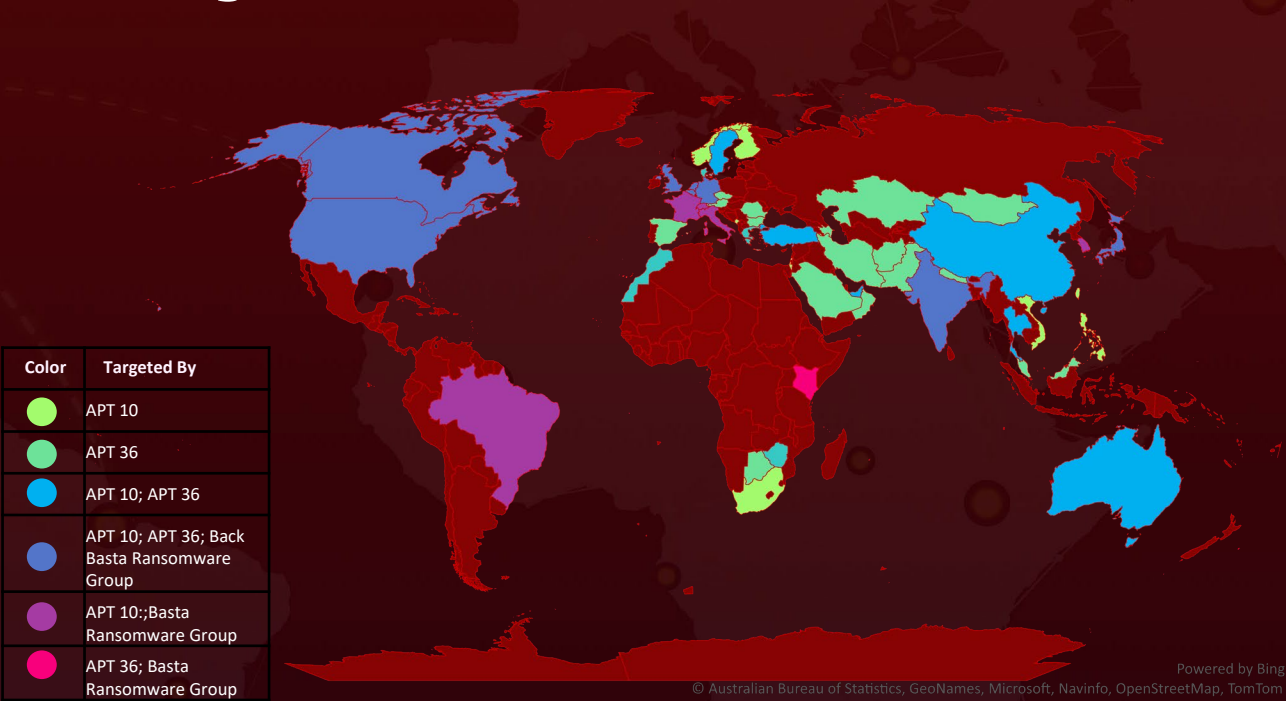
VENDOR	CVE	PATCH LINK
	CVE-2022-3723*	Upgrade Google Chrome to 107.0.5304.87 for Mac and Linux and 107.0.5304.87/.88 for Windows Link: https://www.google.com/intl/en/chrome/?standalone=1
	CVE-2022-31690	Upgrade VMware Spring Security to 5.7.5 and 5.6.9 Links: https://github.com/spring-projects/spring-security/releases/tag/5.7.5 https://github.com/spring-projects/spring-security/releases/tag/5.6.9
OpenSSL	CVE-2022-3602 CVE-2022-3786	Upgrade to OpenSSL version 3.0.7
	CVE-2022-30190* CVE-2021-42287 CVE-2021-42278 CVE-2021-34527* CVE-2020-1472	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30190 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-42287 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-42278 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2020-1472

* zero-day vulnerability

Active Actors

ICON	NAME	ORIGIN	MOTIVE
	APT 10(Stone Panda, menuPassTeam, menuPass,RedApollo,C VNX, Potassium, Hogfish, Happyyongzi, Cicada, Bronze Riverside, CTG-5938,ATK 41,TA429,ITG01)	China	Information theft and espionage
	APT 36(Transparent Tribe, ProjectM , Mythic Leopard,TEMP.Lapis,CopperFieldstone,EarthKarkaddan,C-Major)	Pakistan	Information theft and espionage
	Back Basta Ransomware Group	N/A	Financial Gain

Targeted Locations



Targeted Industries



Energy



Media



Healthcare



Defence



Government



NGOs



Transportation



Aerospace



Pharmaceutical



Financial



Technology



Cryptocurrency



Education



Tele-communications



Think-Tanks



Strategic Consultancies



Manufacturing



Oil & Gas



Embassies



Research Organizations



Construction



Cosmetics



Plumbing



Common MITRE ATT&CK TTPs

TA0043: Reconnaissance	TA0042: Resource Development	TA0001: Initial Access	TA0002: Execution	TA0003: Persistence	TA0004: Privilege Escalation	TA0005: Defense Evasion
T1589: Gather Victim Identity Information	T1583: Acquire Infrastructure	T1190: Exploit Public-Facing Application	T1059: Command and Scripting Interpreter	T1547: Boot or Logon Autostart Execution	T1548: Abuse Elevation Control Mechanism	T1548: Abuse Elevation Control Mechanism
	T1587: Develop Capabilities	T1566: Phishing	T1203: Exploitation for Client Execution	T1543: Create or Modify System Process	T1134: Access Token Manipulation	T1134: Access Token Manipulation
	T1588: Obtain Capabilities		T1053: Scheduled Task/Job	T1574: Hijack Execution Flow	T1547: Boot or Logon Autostart Execution	T1622: Debugger Evasion
			T1569: System Services	T1053: Scheduled Task/Job	T1543: Create or Modify System Process	T1140: Deobfuscate/Decode Files or Information
			T1204: User Execution	T1505: Server Software Component	T1068: Exploitation for Privilege Escalation	T1574: Hijack Execution Flow
					T1574: Hijack Execution Flow	T1562: Impair Defenses
					T1055: Process Injection	T1070: Indicator Removal
					T1053: Scheduled Task/Job	T1112: Modify Registry
						T1027: Obfuscated Files or Information
						T1055: Process Injection
						T1218: System Binary Proxy Execution

TA0006: Credential Access	TA0007: Discovery	TA0008: Lateral Movement	TA0009: Collection	TA0011: Command and Control	TA0010: Exfiltration	TA0040: Impact
T1555: Credentials from Password Stores	T1010: Application Window Discovery	T1210: Exploitation of Remote Services	T1119: Automated Collection	T1071: Application Layer Protocol	T1041: Exfiltration Over C2 Channel	T1486: Data Encrypted for Impact
T1555.003: Credentials from Web Browsers	T1622: Debugger Evasion	T1570: Lateral Tool Transfer	T1005: Data from Local System	T1573: Encrypted Channel		T1490: Inhibit System Recovery
T1555.004: Windows Credential Manager	T1482: Domain Trust Discovery	T1021: Remote Services	T1113: Screen Capture	T1105: Ingress Tool Transfer		
T1003: OS Credential Dumping	T1083: File and Directory Discovery			T1571: Non-Standard Port		
T1539: Steal Web Session Cookie	T1135: Network Share Discovery			T1090: Proxy		
	T1069: Permission Groups Discovery			T1219: Remote Access Software		
	T1057: Process Discovery			T1102: Web Service		
	T1012: Query Registry					
	T1018: Remote System Discovery					
	T1082: System Information Discovery					
	T1614: System Location Discovery					
	T1016: System Network Configuration Discovery					
	T1124: System Time Discovery					

Threat Advisories

<https://www.hivepro.com/google-chromes-seventh-zero-day-of-2022/>

<https://www.hivepro.com/privilege-escalation-in-vmware-spring-security/>

<https://www.hivepro.com/patch-available-for-pre-announced-critical-vulnerability-in-openssl/>

<https://www.hivepro.com/apt10-distributes-lodeinfo-malware-to-deploy-infection-chains/>

<https://www.hivepro.com/exploitation-of-follina-leads-to-takeover-of-domain-controller/>

<https://www.hivepro.com/threat-actors-buy-new-bluefox-stealer-to-exfiltrate-data/>

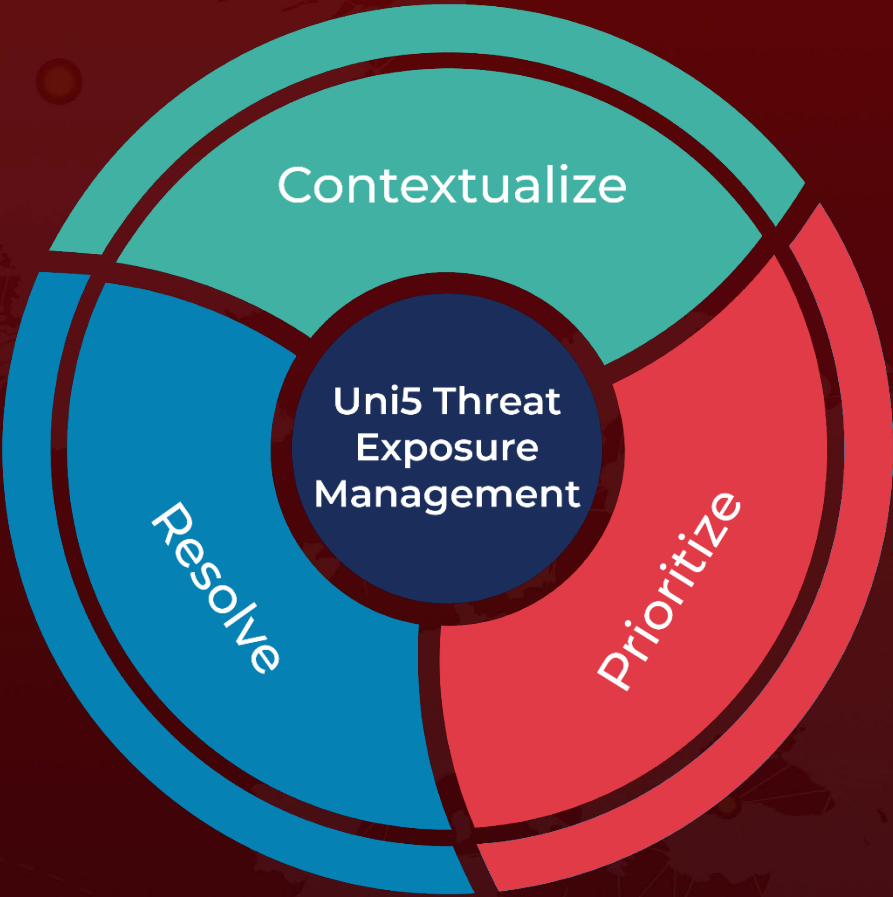
<https://www.hivepro.com/indian-government-targeted-by-apt-36/>

<https://www.hivepro.com/ransomware-black-basta-uses-tools-related-to-fin7/>

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 7, 2022 • 12:31 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com